

COVIDSafe was a digital contact tracing app released by the Australian Government on 26 April 2020 to help combat the ongoing COVID-19 pandemic. The app was intended to augment traditional contact tracing by automatically tracking encounters between users and later allowing a state or territory health authority to warn a user they have come within 1.5 metres (4 ft 11 in) with an infected person for 15 minutes or more. To achieve this, it used the BlueTrace and Herald protocol, originally developed by the Singaporean Government and VMWare respectively, to passively collect an anonymised registry of near contacts. The efficacy of the app was questioned over its lifetime, ultimately identifying just 2 confirmed cases by the time it was decommissioned on 16 August 2022.

History

COVIDSafe first began development in late March, shortly after the Morrison government showed interest in Singapore's TraceTogether app. Development of the app was publicly announced on 14 April 2020, with plans to release it for Android and iOS within a fortnight. The app had a budget of over A\$2 million, A\$700,000 of which went to Amazon Web Services (AWS) for hosting, development, and support. The announcement was immediately met with concerns over the privacy implications of the app and confusion over its distribution. For many, it was unclear if the app would be a feature of the existing Coronavirus Australia app or completely separate. Adding to the confusion, many news reports used images of Coronavirus Australia in their articles, and the COVIDSafe website linked to the Coronavirus Australia apps for a short time after release.

The app launched on 26 April 2020. However, there were early reports that some users had problems with the sign-up. For example, those who entered their phone number during sign-up received the following message: "Error verifying phone number. Please check your details and try again."

Within 24 hours of COVIDSafe's release it had been downloaded by over a million people, and

within 48 hours more than two million. By the second week more than four million users had registered. Despite this, state and territory health authorities were not able to access data collected through the app as the health authority portal had not yet been completed.

Accompanying the release, Peter Dutton, then Minister for Home Affairs, announced new legislation that would make it illegal to coerce one into submitting a contact report, even if a person had already registered with the app and tested positive for COVID-19. A determination, titled Biosecurity Determination 2020, was put in place, with the Privacy Amendment (Public Health Contact Information) Bill 2020 being later introduced on 6 May 2020 to codify it. The legislation further governs how data collected by the app will be stored, submitted and processed.

In early May 2020, the Senate Select Committee on COVID-19 held a public hearing on the app, focusing particularly on its effectiveness and privacy implications and the source code for the app was released publicly.

In mid May 2020, the Australian Chief Medical Officer announced that the app was fully functional. The next day it was reported that the app had reached 5.7 million downloads, approximately 23% of Australia's total population. On 20 May 2020, data was accessed for the first time following an outbreak at Kyabram Health in Victoria.

By mid June, over a month since the launch of the app, the app had yet to identify any contacts not already discovered through traditional contact tracing techniques, strengthening growing concerns over the efficacy of the app. Adding to this, some estimates put the likelihood of the app registering a random encounter at just ~4%. Concurrently, the Google/Apple exposure notification framework began rolling out to users, with the Italian Immuni being the first app to make use of it.

In late June, following a "second wave" in Victoria sparked by family gatherings, COVIDSafe data was accessed by contact tracers over 90 times. The app, again, was unable to identify undetected transmission. At the same time, a COVID-19 positive protester who attended the

Melbourne Black Lives Matter rally on 6 June 2020 was criticised in the media for having not downloaded the app. Despite the identification of at least two further cases in attendance, to date no transmission has been found to originate from the protests.

On 20 July 2020, the government was criticised for contracting out part of the app's development and support to a company with ties to the Liberal Party. Mina Zaki, the wife of the CEO of Delv Pty Ltd, was a Liberal Party candidate for the federal seat of Canberra in the 2019 election. Delv was engaged after the initial release of the app to assist with development, and was also the primary developer of the Coronavirus Australia app.

In a 22 July 2020 Sky News interview, Minister for Government Services Stewart Robert blamed the failure of COVIDSafe on the unwillingness of Apple and Google to modify their existing, globally deployed, Exposure Notification framework (ENF) to work with the app. ENF is an alternative, entirely incompatible, digital contact tracing protocol considered to be more reliable at detecting contact traces than competing protocols. For the app to take advantage of the framework, either the framework or app would need to be almost completely rewritten. On 1 August 2020, NSW Health announced the app had helped them trace new contacts. They accessed the app data on a coronavirus case and identified 544 additional people, two of whom tested positive to COVID-19. By late October, the app had identified a total of 17 new cases.

By 29 November 2020, the Digital Transformation Agency was reportedly considering incorporating VMWare's Herald protocol to improve performance and detection success rate.

On 19 December 2020, the Digital Transformation Agency announced the app had been updated to incorporate VMWare's Herald protocol, to improve app performance. The update reportedly helps address situations where communication between devices might fail, such as when the device is locked or the app is running in the background.

On 2 February 2021, the Digital Transformation Agency announced a new update enabling the app to display state and territory COVID-19 case statistics. The update reportedly allowed

users to change their registration postcode from within the app, which previously required reinstallation.

It was announced on 26 February 2021 that the app had been updated to feature state and territory restrictions, as well as improving battery consumption on Android devices.

Because of the ongoing technical problems surrounding the COVIDSafe app, the Victorian government developed the Service Victoria QR Code app to augment tracing efforts within the state. Use of the app is mandatory for all Victorian businesses, organisations, clubs and events.

Similarly, every other state and territory in Australia has their own QR-code based solution:

On 2 December 2021, NSW and Victorian health officials admitted to The Guardian that the data collected by the app had not been used a single time in 2021, despite the extensive outbreaks and lockdowns that year. In response to the poor performance of the app, Federal Labor Party politicians called for the app to be discontinued, while the Morrison government began engaging with states to find a future use of the app.

On 16 August 2022, the incumbent Albanese Government decommissioned the app, shutting down remaining infrastructure and removing it from Google Play and the Apple App Store. The total cost of the app over its lifetime rounded out to \$21 million, with \$10 million going to development costs alone.

Contact tracing

The app is built on the BlueTrace protocol originally developed by the Singaporean Government. A stated priority of the protocol was the preservation of privacy. In accordance with this, personal information is only collected once at the point of registration and subsequently used purely to contact potentially infected patients. Additionally, users are able to opt out at any time, clearing all personal information. The contact tracing mechanism is

executed locally on an individual's device using Bluetooth, storing all encounters in a contact history log chronicling contact for the past 21 days. Users in contact logs are identified using anonymous time-shifting "temporary IDs" issued by a central Department of Health (DoH) server. Consequently, a user's identity and contact patterns cannot be determined by anyone not authorised by the DoH. Furthermore, since temporary IDs change on a regular basis, malicious third parties cannot track users by observing log entries over time.

Once a user tests positive for infection, the DoH requests their contact log. If consent is given, the logs are transmitted to a central server where temporary IDs are matched with contact information. Health authorities are not able to access log entries about foreign users, so those entries are sent to the appropriate health authority to be processed domestically. Once a contact has been identified, the DoH contacts the individual.

Although the app is commonly described as only logging encounters longer than 15 minutes and closer than 1.5 metres (4 ft 11 in), the app actually indiscriminately logs most encounters. It is only once the health authority receives a contact log that it is filtered to encounters within those parameters.

Reporting centralisation

BlueTrace's employment of a centralised reporting architecture has created concerns over its privacy implications. Under a centralised report processing protocol, a user must upload their entire contact log to a health authority administered server, where the health authority is then responsible for matching the log entries to contact details, ascertaining potential contact, and ultimately warning users of potential contact. In contrast, the Exposure Notification framework and other decentralised reporting protocols, while still having a central reporting server, delegate the responsibility of processing logs to clients on the network. Instead of a client uploading their contact history, it uploads a number from which encounter tokens can be derived by individually. Clients then check these tokens against their local contact logs to

determine if they have come in contact with an infected patient. Inherent in the fact the protocol never allows the government access to contact logs, this approach has major privacy benefits. However, this method also presents some issues, primarily the lack of human in the loop reporting, leading to a higher occurrence of false positives. Decentralised reporting protocols are also less mature than their centralised counterparts.

Protocol change to Exposure Notification

During the 6 May 2020 Senate Select Committee public hearing on COVID-19 and the COVIDSafe app, the Digital Transformation Agency (DTA) announced they were looking into transitioning the protocol from BlueTrace to the Google and Apple developed Exposure Notification framework (ENF). The change was proposed to resolve the outstanding issues related to performance of third-party protocols on iOS devices. Unlike BlueTrace, the Exposure Notification framework runs at the operating system level with special privileges not available to any third-party frameworks. The adoption of the framework is endorsed by multiple technology experts.

Transitioning from BlueTrace to ENF presented several issues, most notably that, as the app cannot run both protocols simultaneously, any protocol change would be a hard cut between versions. This would result in the app no longer functioning for any users who had not yet updated to the ENF version of the app. Additionally, the two protocols are almost completely incompatible, meaning the vast majority - all but the UI - of the COVIDSafe app would have to be redeveloped. Similarly, because of the change from a centralised reporting mechanism to a decentralised one, very little of the existing server software would be usable. The role of state and territory health authorities in the process would also change significantly, as they would no longer be responsible for determining and contacting encounters. This change would involve retraining health officials and penning new agreements with states and territories.

Up until at least 18 June 2020, the DTA was experimenting with ENF, however in an interview

with The Project held on 28 June 2020, Deputy Chief Medical Officer Dr Nick Coatsworth stated COVIDSafe would "absolutely not" transition to ENF. He reasoned the government would never transition to any contact tracing solution without human-in-the-loop reporting, something that no decentralised protocol can support.

Issues

Issues on iOS

Versions 1.0 and 1.1 of COVIDSafe for iOS did not scan for other devices when the application was placed in the background, resulting in far fewer recorded contacts than was possible. This was later corrected in version 1.2. Additionally, until the 18 June 2020 update, a bug existed where locked iOS devices were unable to fetch new temporary IDs. Devices collected 24–48 hour pools of temporary IDs in advance, meaning a device could easily exhaust its pool unless the phone was unlocked specifically when the app was scheduled to replenish the pool.

Additionally, all third-party digital contact tracing protocols experience degraded performance on iOS devices, particularly when the device is locked or the app is not in the foreground. This is a characteristic of the operating system, stemming from how iOS manages its battery life and resource priority. The Android app does not experience these issues because Android is more permissive with background services and the app can request the operating system to disable battery optimisation.

Country calling code restrictions

COVIDSafe requires an Australia mobile number to register, meaning foreigners in Australia need a local SIM card. Initially, residents of Norfolk Island, an external territory of Australia, were unable to register with the app as they used a different country code to mainland Australia, +672 instead of +61. The Australian government released an update resolving the issue on 18 June 2020.

Privacy concerns

Upon announcement, the app was immediately met with widespread criticism over the potential privacy implications of tracking users. While some criticism was attributed to poor communication, fears were further stoked when Prime Minister Scott Morrison and Deputy Chief Medical Officer Paul Kelly refused to rule out the possibility of making the app compulsory, with Morrison stating the next day it would not be mandatory to download the app. Additionally, several privacy watchdogs raised concerns over the data collected by the app, and the potential for the centralised reporting server to become a target for hackers. To address concerns, the Attorney General launched an investigation into the app to ensure it had proper privacy controls and was sufficiently secure. The Minister for Home Affairs, Peter Dutton, also announced special legislation to protect data collected through the app. The app was supposed to be source available to allow it to be audited and analysed by the public, however, this was delayed until a review by the Australian Signals Directorate had been completed. On 8 May 2020, the source code was released.

Issue was also taken with the fact the backend of the app runs on the Amazon Web Services (AWS) platform, meaning the US Government could potentially seize the data of Australian citizens. Data is currently stored within Australia in the AWS Sydney region data centres. In a public hearing on COVIDSafe, Randall Brugeaud, CEO of the Digital Transformation Agency, explained that the decision to use AWS over purely Australian owned cloud providers was done on the basis of familiarity, scalability, and resource availability within AWS. The AWS contract was also drawn from a whole of government arrangement.

Following the global rollout of the Google and Apple developed Exposure Notification Framework (ENF) in late June 2020, public concerns were raised that the government or the companies were tracking users without their knowledge or consent. These claims are false, as COVIDSafe and ENF are completely incompatible, and ENF is disabled until a compatible app is

installed and explicit user consent is given. Even if a third party were to obtain the encounter log of a user, no persons could be identified without also holding the logs of other users the client has encountered.

Australia's Inspector-General of Intelligence and Security reported that several of Australia's intelligence and security agencies collected data from COVIDSafe in its first months of operation. The report does not state which specific agencies collected the data and whether or not it was decrypted.

In June 2021 the state government of Western Australia "was forced to introduce legislation" when Western Australian police used data collected by the COVID SafeWA app for purposes other than contact tracing. Police stated that their use of this data was lawful, and that they could not stop using this data in criminal investigations while lawful to do so. Police Commissioner Chris Dawson defended this by pointing out that the "terms and conditions stated data could be accessed for a lawful reason" and while he accepts "people don't always read fine print on insurance policies or whatever," their use of the data in these circumstances was lawful.

Attorney General privacy impact assessment

On 25 May 2020, the Attorney General report and subsequent response by the Department of Health was released, the following recommendations were made:

Release the Privacy Impact Assessment and the app source code

Major changes should be reviewed for privacy impact

A legislative framework put in place to protect the user

Certain screens be rearranged to better communicate information

Make clear what a user should do if they are pressured to reveal their contact logs, or are pressured into installing the app

Generalised collection of age

Gather consent from users both at registration, and at submission of contact logs

Create a specific privacy policy for the app

Make it easier to rectify personal information

Raise public awareness about the app and how it works

Development of training and scripts for health officials

Put in place contracts with state and territory health authorities

Allow users to register under a pseudonym

Seek independent review over security of the app

Review the contract with AWS

Ensure ICT contracts are properly documented

Investigate ways to reduce the number of digital handshakes

A special consent process for underage users

In the Department of Health's response, they agreed to all suggestions with exception to "rectification of personal information". Rather than building a process to do so, a user could uninstall and reinstall the app to change their personal information. A process to formally correct information was to be introduced later.

Independent analysis

On 29 May 2020, a group of independent security researchers including Troy Hunt, Kate Carruthers, Matthew Robbins, and Geoffrey Huntley released an informal report raising a number of issues discovered in the decompiled app. Their primary concerns were two flaws in the implementation of the protocol that could potentially allow malicious third parties to ascertain static identifiers for individual clients. Importantly, all issues raised in the report were related to incidental leaking of static identifiers during the encounter handshake. To date, no code has been found that intentionally tracks the user beyond the scope of contact

tracing, nor code that transmits a user's encounter history to third parties without the explicit consent of the user. Additionally, despite the flaws discovered through their analysis, many prominent security researchers publicly endorse the app.

The first issue was located in `BLEAdvertiser.kt`, the class responsible for advertising to other BlueTrace clients. The bug occurred with a supposedly random, regularly changing three-byte string included in that was, in fact, static for the entire lifetime of an app instance. This string was included with all handshakes performed by the client. In OpenTrace this issue did not occur, as value changes every 180 seconds. While likely not enough entropy to identify individual clients, especially in a densely populated area, when used in combination with other static identifiers (such as the phone's model) it could have been used by malicious actors to determine the identity of users. This issue was addressed in the 13 May 2020 update.

The second issue was located in `GattServer.kt`, the class responsible for managing BLE peripheral mode, where the cached read payload is incorrectly cleared. Although it functioned normally when a handshake succeeded, a remote client who broke the handshake would have received the same TempID for all future handshakes until one succeeded, regardless of time. This meant a malicious actor could always intentionally break the handshake and, for the lifetime of the app instance, the same TempID would always be returned to them. This issue was resolved in OpenTrace, yet was unfixed in COVIDSafe until the 2020-05-13 update.

Other issues more inherent to the protocol include the transmission of device model as part of the encounter payload, and issues where static device identifiers could be returned when running in GATT mode. Many of these are unfixable without redesigning the protocol, however they, like the other issues, pose no major privacy or security concerns to users.

Legislation

The Biosecurity Determination 2020, made with the authority of the Biosecurity Act 2015, governs how data collected by the COVIDSafe app is stored, submitted, and processed. Later a

separate bill was introduced to codify this determination, the Privacy Amendment (Public Health Contact Information) Bill 2020. The determination and bill makes it illegal for anyone to access COVIDSafe app data without both the consent of the device owner and being an employee or contractor of a state or territory health authority. Collected data may be used only for the purpose of contact tracing or anonymous statistical analysis, and data also cannot be stored on servers residing outside Australia, nor can it be disclosed to persons outside Australia. Additionally, all data must be destroyed once the pandemic has concluded, overriding any other legislation requiring data to be retained for a certain period of time. The bill also ensures no entity may compel someone to install the app. Despite this there have been reports of multiple businesses attempting to require employees to use the app.

See also

COVID-19 apps

Telecommunications (Interception and Access) Amendment (Data Retention) Act 2015

Mass surveillance in Australia § Telecommunications and Other Legislation Amendment (Assistance and Access) Act

References

External links

GitHub

Senate Select Committee on COVID-19 Public Hearing on COVIDSafe, 2020-05-06 (YouTube)

COVIDSafe App Teardown & Panel Discussion